

06 — Security, Privacy & PKI

06 — Security, Privacy & PKI

Revision: 1 **Last modified:** 2026-07-05T14:20:00Z **Status:** Draft
— consolidated from 04-security-privacy-pki.md and v05-security/
*.

1. Position and invariants

This section owns the **security spine** of HelixVPN: zero-trust routing, identity, PKI, no-logging, kill-switch/DNS-leak protection, audit, and the post-quantum handshake. It defines the invariants; the data plane, control plane, and client-core docs define the mechanisms that enforce them.

1.1 Non-negotiable invariants (S1-S11)

#	Invariant	Enforced where
S1	Zero-trust default-deny — no peer reaches anything without an explicit compiled policy rule.	Policy compiler → AllowedIPs + edge verdict map
S2	Device private keys never leave the device; only the 32-byte WG public key is registered.	Enrollment protocol + device keystore
S3	Need-to-know map distribution — a device's NetworkMap contains only policy-granted peers.	Coordinator filter before serialization
S4	Short-lived control-channel mTLS (≤ 24 h leaf); WG data channel uses separate Noise IK.	PKI service + TLS 1.3 mutual auth
S5	Revocation latency == convergence SLO ($p99 < 1$ s).	Revocation pipeline + event fan-out
S6	No durable connection/traffic log — by construction; CI schema-lint blocks flow tables.	Data model + tools/schemalint

#	Invariant	Enforced where
S7	Control actions are audited; traffic is not.	audit_events closed vocabulary
S8	Edge hardening — rootless Podman, seccomp allowlist, read-only rootfs, no SSH.	Edge quadlet + container profile
S9	Kill-switch + DNS-leak protection are core-owned state, not hand-edited rules.	helix-core state machine + OS firewall shims
S10	PQ is hybrid, never PQ-only — PSK derived from PQ KEM mixed into classical WG handshake.	helix-pki PQ module (Phase 2)
S11	The tenant CA root and Postgres are the only secrets to protect; data-plane nodes are cattle.	KMS/HSM root, offline root, backups

A violation of any invariant is a release blocker, not a tunable.

2. Trust model and identity

2.1 Two authentication channels

Channel	Mechanism	Owner
Control	mTLS with ≤ 24 h device cert signed by tenant CA	Control plane / PKI
Data	WireGuard Noise IK handshake; peer pubkeys from filtered map	Data plane / helix-wg

The channels are **independent**: stealing a device cert does not yield the WG private key, and vice versa.

2.2 Identity modes

- **Managed (OIDC)** — Console/API users authenticate via Authorization Code + PKCE against a tenant-configured IdP. HelixVPN is an OIDC Relying Party, never an IdP. Roles map IdP group claims to admin / operator / member.
- **Anonymous (device tokens)** — The privacy-VPN default. A high-entropy enroll token is shown once; only its Argon2id hash is stored. The resulting users row has email = NULL, oidc_sub = NULL — no reverse-link to a human.

2.3 Defence-in-depth

- RBAC gates Console/API actions.
 - Postgres FORCE ROW LEVEL SECURITY is the floor — a logic bug cannot cross tenants.
 - Every privileged identity action is audited (§7).
-

3. Enrollment

Enrollment mints a network identity **without the device ever surrendering its WireGuard private key**.

1. Admin mints a single/bounded-use, TTL'd enroll token; plaintext shown once.
2. Device generates WG + Ed25519 leaf keypairs locally; sends only public material (wg_pubkey, CSR).
3. Server verifies token (constant-time Argon2id hash check), allocates overlay IP, inserts devices row, signs a ≤ 24 h leaf cert.
4. Device uses the new cert for WatchNetworkMap; the coordinator pushes a policy-filtered map.

Key security properties:

- CSR proof-of-possession ensures the device controls the leaf private key.
 - Rate limiting + per-source-IP buckets resist enroll flooding.
 - UNIQUE (tenant_id, wg_pubkey) prevents key reuse across devices.
 - bind_kind prevents a connector token from enrolling a client.
-

4. PKI — key hierarchy, certs, rotation, revocation

4.1 Key hierarchy

Tier	Role	Lifetime	Storage
Tenant root CA	Signs the issuing CA once	~10 y	Offline / KMS / HSM
Issuing CA	Signs every device leaf	~1 y	Online signer (KMS-backed)
Device leaf	mTLS control channel	≤ 24 h	Device OS keystore
	Tunnel identity	Rotatable	

Tier	Role	Lifetime	Storage
Device WG key			Device OS keystore
PQ PSK	HN DL hedge	Per-session	Ephemeral memory only

Three **independent** key planes (control, data, PQ) prevent a single compromise from cascading.

4.2 Certificate profile

- Ed25519 keys (ECDSA-P256 fallback if a platform rejects Ed25519 client certs).
- TLS 1.3 mutual auth only; no downgrade.
- SPIFFE URI SAN binds the cert to a device id.
- CA:FALSE, clientAuth EKU, ≤ 24 h validity.

4.3 Lifecycle

- **Auto-renew:** core renews at `not_after - renewSkew` ($\text{renewSkew} = \max(1\text{h}, 0.2 \times \text{TTL})$) over the existing authenticated channel — no new enroll token.
- **WG key rotation:** device generates a new keypair locally; coordinator swaps the edge peer atomically. Old key removed before new key announced.
- **Issuing-CA rotation:** offline root signs a new intermediate; both trusted during a 24 h overlap.

4.4 Revocation (< 1 s)

`device.revoked` is the security analogue of the convergence SLO:

1. Identity/pki marks the cert revoked and emits `device.revoked` in one transaction.
2. Coordinator removes the WG peer at the edge and drops verdict-map entries.
3. Affected open streams receive a `MapDelta{remove peer}`.
4. The revoked device's control stream is force-closed; its serial is blacklisted in memory.

No CRL/OCSP on the data path — short-lived certs + active push provide revocation.

5. Edge hardening (S8)

The Rust data-plane edge is the only component reachable from the hostile Internet on the data port.

- **Rootless Podman quadlet** with read-only rootfs.
 - DropCapability=ALL, add only CAP_NET_ADMIN + CAP_NET_RAW.
 - Default-deny seccomp allowlist — no execve, ptrace, mount, kexec.
 - Distroless image — no shell, no SSH.
 - Host firewall: only :443/udp + :443/tcp + control API open.
-

6. No-logging as code (S6)

The privacy promise is a **build property**, enforced by absence and a CI schema-lint.

- No durable connections, sessions, flows, traffic, packets, or dns_queries tables.
 - Live presence lives only in Redis with a TTL (default 45 s = 3 × heartbeat interval).
 - devices.last_seen_at is coarse (≥5 min) and carries no destination.
 - tools/schemalint fails the build if a durable table has a connection-log shape (forbidden names, or src/dst + bytes/ts outside audit_events).
 - A paired §1.1 mutation plants a flows(src,dst,bytes,ts) table and asserts the lint FAILs.
-

7. Audit — control actions only (S7)

audit_events records **who did what to control objects**, never traffic.

- Closed AuditAction enum: device.enrolled, device.revoke, device.cert.issued, device.cert.rotated, policy.create, policy.activate, policy.rollback, connector.attached, connector.prefixes.changed, enroll_token.mint, enroll_token.used, tenant.create, user.role.change, auth.login, auth.enroll.denied.
- Synchronous, in-transaction write — a committed mutation cannot exist without its audit row.
- Append-only by grant: helix_app has no UPDATE/DELETE on audit_events.
- meta JSON shape-checked to forbid traffic keys (dst_ip, bytes_in, etc.).

- Phase 2: optional hash-chained `meta.prev_hash` for tamper-evidence.

8. Kill-switch & DNS-leak protection (S9)

A core-owned state machine drives the OS firewall; the rules are an **output** of state transitions, not an input.

State	Egress	DNS
Disconnected	all (killswitch off) or none (lockdown)	system
Connecting / Reconnecting	only gateway endpoint IP:port	blocked
Connected	only via tunnel + gateway endpoint	tunnel DNS only; off-tunnel :53/:853 dropped
Blocked	only gateway endpoint	blocked

- Firewall is applied **before** the network operation on every transition.
- Fail-closed on tunnel drop; revert only on user-initiated stop.
- Closed rules persist across core crash (Linux ExecStopPost gating, Windows persistent WFP filters, Apple `includeAllNetworks`).
- IPv6 is either fully captured or fully blocked — never a partial-capture leak.

9. Post-quantum handshake (S10)

WireGuard's optional 32-byte PSK slot is filled with a key derived from a post-quantum KEM exchange, **without forking WG crypto**.

- **Hybrid, never PQ-only:** an attacker must break both classical X25519 ECDH and the PQ KEM.
- **Default KEM:** ML-KEM-768 (FIPS 203); Phase-2 opt-in for ML-KEM-768 + Classic McEliece or Rosenpass evaluation.
- The PQ exchange rides the **authenticated mTLS control channel** — no new public listener.
- `psk = HKDF-SHA256(shared_secret, salt=session_id, info="helix-pq-psk-v1")`.
- PSK is rotated on every WG rekey (~120 s); ephemeral, never persisted.

- MVP ships classical WG with the PSK seam reserved; PQ is Phase 2.

10. Threat model

The threat model (STRIDE per component + LINDDUN privacy) is the authoritative justification for every mechanism above. Key threats → mitigations:

Threat	Mitigation
Spoof control RPC	mTLS device cert + CSR proof-of-possession
Spoof WG peer	Noise IK + peer pubkey from signed map
Lateral movement to ungranted CIDR	Default-deny AllowedIPs + edge verdict map
Over-broad map distribution	Need-to-know coordinator filter (S3)
Traffic correlation logging	No durable connection log (S6) + schema-lint
DNS/plaintext leak on drop	Kill-switch state machine (S9)
Harvest-now-decrypt-later	Hybrid PQ PSK (S10)
Edge container escape	Rootless, seccomp, read-only, no shell (S8)
Insider cross-tenant write	RLS FORCE ROW LEVEL SECURITY

Residual risks (R-CA, R-RELAY, R-COMPEL, R-INS, R-DEV, R-RACE, R-TA, R-CENSOR) are tracked honestly in the threat-model nano-detail.

11. Secrets management and backup

The durable secret surface is deliberately tiny (S11):

- **Protect:** tenant CA root key + Postgres.
 - **Cattle:** data-plane nodes, edge config — reprovisioned from IaC.
 - CA root in KMS/HSM or offline; online pki service signs only with the issuing intermediate.
 - Enroll/API tokens hashed at rest; no credential logged or printed by helixvpctl.
 - Backup: GPG/age-encrypted Postgres PITR + CA root; 3-2-1; quarterly DR drill.
-

12. Cross-references

- Zero-trust contract → [../v05-security/zero-trust-and-default-deny.md](#)
- Identity & enrollment → [../v05-security/identity-and-enrollment.md](#)
- PKI & certificates → [../v05-security/pki-and-certs.md](#)
- Kill-switch & DNS leak → [../v05-security/kill-switch-and-dns-leak.md](#)
- No-logging as code → [../v05-security/no-logging-as-code.md](#)
- Audit & compliance → [../v05-security/audit-and-compliance.md](#)
- Threat model → [../v05-security/threat-model.md](#)
- Post-quantum handshake → [../v05-security/post-quantum.md](#)
- Control-plane PKI/identity mechanics → [04 — Control Plane](#)
- Data-plane policy enforcement → [03 — Data Plane](#)
- Client core kill-switch/PQ implementation → [05 — Client Core & UI](#)

Sources: docs/research/mvp/final/04-security-privacy-pki.md, v05-security/.md.*